

WEP / WPA / WPA2 / WPA3 — Study Guide

1. Overview

WEP, WPA, WPA2, and WPA3 are the successive generations of **Wi-Fi security protocols** standardized to protect wireless network traffic — each designed to address specific cryptographic and structural weaknesses discovered in its predecessor. Understanding this lineage matters because vulnerabilities in earlier protocols remain relevant wherever legacy hardware or misconfiguration keeps them in use, and because each new generation's design choices are best understood as direct responses to the previous generation's specific failures.

Protocol	Introduced	Encryption	Current status
WEP	1997	RC4 stream cipher	Broken — trivially crackable, must never be used
WPA	2003	RC4 with TKIP	Deprecated — interim fix, largely obsolete
WPA2	2004	AES-CCMP	Widely deployed; secure when configured correctly, though not free of weaknesses
WPA3	2018	AES-GCMP, SAE handshake	Current standard; addresses WPA2's most significant structural weaknesses

2. WEP (Wired Equivalent Privacy)

WEP was the original Wi-Fi security protocol, intended to provide confidentiality comparable to a wired network. It uses the **RC4 stream cipher** combined with a static, shared key and a short **24-bit Initialization Vector (IV)**.

Core weaknesses:

- The 24-bit IV space is small enough that IV reuse becomes statistically inevitable on any moderately busy network, and IV reuse with the same key catastrophically weakens RC4's keystream secrecy.

- Known biases in RC4's key-scheduling algorithm, combined with predictable IV structure, allow a passive attacker to recover the WEP key by statistically analyzing a sufficient volume of captured packets — no brute-forcing of the key itself is required.
- WEP's integrity check (CRC-32) is not cryptographically secure and can be manipulated, allowing packet forgery and injection attacks that let an attacker actively generate additional traffic to accelerate key recovery.
- As a result, WEP can typically be broken in minutes with widely available tools, regardless of how "strong" (long/random) the configured key is — the flaw is structural, not a matter of key strength.

Current status: WEP must be considered completely broken and unsuitable for any use; its continued presence anywhere is a critical security finding.

3. WPA (Wi-Fi Protected Access)

WPA was released in 2003 as an **interim fix**, deployable via firmware updates to existing WEP-era hardware, while the more thorough WPA2 standard was still being finalized. It introduced **TKIP (Temporal Key Integrity Protocol)**, which retained RC4 as the underlying cipher (for hardware compatibility) but added per-packet key mixing, a sequence counter to prevent replay attacks, and a stronger message integrity check (nicknamed "Michael").

Weaknesses:

- Because TKIP still relies on RC4, it inherits some of RC4's underlying cryptographic weaknesses, and several practical attacks against TKIP itself have since been demonstrated (e.g., partial keystream recovery enabling limited packet decryption/forgery).
- WPA/TKIP was always intended as a transitional measure, not a long-term solution.

Current status: deprecated; modern devices and standards bodies have phased out TKIP support in favor of WPA2/WPA3's AES-based encryption.

4. WPA2 (Wi-Fi Protected Access 2)

WPA2, standardized in 2004, replaced RC4/TKIP with **AES encryption in CCMP mode** (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol — see the AES guide), providing genuinely strong, modern

symmetric encryption for wireless traffic. WPA2 became the dominant Wi-Fi security standard for well over a decade.

Two operating modes:

- **WPA2-Personal (PSK — Pre-Shared Key)** — all devices on the network share a single passphrase-derived key, appropriate for home and small-office use.
- **WPA2-Enterprise** — uses 802.1X authentication against a RADIUS server, issuing individual credentials/certificates per user or device, appropriate for larger organizations needing per-user accountability and easier credential revocation.

Known weaknesses:

- **The 4-way handshake** used to establish a session key is vulnerable to offline dictionary/brute-force attacks against WPA2-Personal: an attacker can passively capture the handshake (or actively force one via a deauthentication attack) and then attempt to crack the pre-shared passphrase offline, entirely independent of network proximity or rate limiting — meaning WPA2-Personal's real-world security is only as strong as the chosen passphrase.
- **KRACK (Key Reinstallation Attack, 2017)** — a protocol-level flaw in the 4-way handshake's implementation allowed an attacker to force reuse of an already-used encryption key/nonce under certain conditions, potentially enabling decryption or injection of traffic; this was addressed via patches to the handshake implementation across vendors rather than requiring a full protocol replacement.
- WPA2-Enterprise, while much more resistant to offline passphrase attacks (since there's no single shared passphrase), still depends on proper certificate validation on client devices — misconfigured clients that don't validate the RADIUS server's certificate can be tricked into authenticating to a rogue access point (see the Evil Twin/Rogue AP guide).

5. WPA3 (Wi-Fi Protected Access 3)

WPA3, introduced in 2018, was designed specifically to close WPA2's most consequential structural gaps, particularly around passphrase-based authentication.

Key improvements:

- **SAE (Simultaneous Authentication of Equals)**, also known as the "Dragonfly" handshake, replaces WPA2's 4-way handshake for WPA3-Personal. SAE is a password-authenticated key exchange resistant to **offline dictionary attacks** — an attacker who captures the handshake cannot simply brute-force the passphrase offline the way they could against WPA2's handshake, because SAE requires active, real-time interaction with the network for each individual guess attempt, which can be rate-limited and detected.
- **Forward secrecy** — even if a WPA3 passphrase is later compromised, previously captured encrypted traffic cannot be decrypted retroactively, since session keys aren't derivable purely from the long-term passphrase (directly analogous to the forward secrecy concept in the TLS guide).
- **AES-GCMP** (Galois/Counter Mode) replaces CCMP for stronger, authenticated encryption, and WPA3-Enterprise offers an optional 192-bit security mode for organizations requiring higher assurance levels.
- **Individualized data encryption on open networks** — via Opportunistic Wireless Encryption (OWE), WPA3 also improves security on networks that intentionally have no password at all (e.g., public hotspots), encrypting each client's traffic individually rather than leaving it entirely in the clear.

Adoption considerations: WPA3 requires both router/access point and client device support; mixed environments often run "WPA2/WPA3-transitional" modes for backward compatibility, which can reintroduce some WPA2-level weaknesses for devices that fall back to the older protocol — full security benefits are only realized once WPA2 fallback is disabled entirely.

6. Comparative Summary

Feature	WEP	WPA	WPA2	WPA3
Encryption	RC4	RC4 (TKIP)	AES (CCMP)	AES (GCMP)
Handshake/key establishment	Static key	4-way handshake (TKIP-derived)	4-way handshake	SAE (Dragonfly)
Offline dictionary attack resistance	None	Weak	Vulnerable (Personal mode)	Strong (SAE resists offline attack)

Feature	WEP	WPA	WPA2	WPA3
Forward secrecy	No	No	No	Yes
Open-network traffic protection	N/A	N/A	None	OWE (individualized encryption)

7. Summary

Each generation of Wi-Fi security protocol addressed specific, concrete failures in its predecessor: WEP's structurally broken key/IV scheme, WPA's RC4-dependent interim fix, WPA2's vulnerability to offline passphrase attacks against its 4-way handshake, and WPA3's SAE-based resistance to exactly that offline attack class. Legacy protocol support (especially WEP, and WPA2 fallback in transitional WPA3 deployments) remains one of the most common real-world wireless security gaps, since backward compatibility considerations frequently keep older, weaker protocols enabled long after a stronger successor has become available.